

CANLIFAL_BACKEND_ARCHITECTURE.md — PHASE 1 AUDIT (§1-A, §1-D)

Bu doküman **mevcut** backend'in gerçek durumunu anlatır. Hedef mimariyi değil, bugün çalışan sistemi tarif eder. Hiçbir kod değiştirilmemiştir.

A. MİMARİ ENVANTERİ

Konu	Mevcut durum
Framework	App Router tabanlı tek monolit web uygulaması (v14.2.28), TypeScript
Runtime	Node.js (standalone build), tek proses / tek deployment
Servis sayısı	1 ana backend (canlifal.com) + 1 eski yardımcı backend (canlifalapi.abacusai.app , sadece bazı PK uçları için ayakta)
Veritabanı	PostgreSQL, tek instance, ORM ile erişim. 198 model / 2338 alan / 429 indeks
DB bağlantı politikası	Kısa idle_session_timeout , max 25 eşzamanlı bağlantı, 5 sn statement timeout, 30 sn idle-in-transaction timeout — bağlantılar geçici kabul edilmeli
Cache	Redis YOK. lib/cache.ts içinde “redis uyumlu” process içi bellek cache (getCache / invalidateCache / CACHE_TTL + hazır getter’lar: gift types, payment methods, credit packages, homepage kartları, platform settings, achievements, chat room)
Queue / job	YOK. Zamanlanmış iş, kuyruk, worker yok. Uzun işler istek içinde yapılıyor
Realtime	SSE (Server-Sent Events) + polling. WebSocket / socket.io YOK.
Realtime event bus	5 adet process içi bellek bus: chat-events.ts , room-events.ts , stream-events.ts , voice-room-events.ts , chat-dj-events.ts
Storage	Cloudflare R2 (gift/ prefix, public CDN cdn.girlive.com) — lib/r2-storage.ts . Eski AWS S3 nesneleri lib/s3.ts uyumluluk katmanı üzerinden okunmaya devam ediyor
Auth (web)	NextAuth — Google OAuth + Credentials (e-posta/şifre)
Auth (mobil)	Özel JWT: access + refresh (lib/mobile-auth.ts). Sosyal: Google, TikTok, Apple

Konu	Mevcut durum
Auth birleşimi	<code>authenticateRequest()</code> tek doğrulama noktası: mobil Bearer JWT veya web oturumu. 60 sn'lik auth cache (<code>lib/perf.ts</code>)
Telefon / OTP girişi	YOK (§5 boşluğu)
Authorization	Rol alanı üzerinden dağınık kontrol (admin/teller/user). Merkezi RBAC/PBAC katmanı, Permission tablosu YOK
WebRTC / signaling	Tencent TRTC (usersig/token uçları) + DB tabanlı signaling tabloları (<code>RoomSignal</code> , <code>VoiceSignal</code> , <code>VideoStreamSignal</code>)
Push provider	OneSignal (<code>lib/onesignal.ts</code> , <code>lib/onesignal-admin.ts</code> , <code>lib/push-notifications.ts</code> , <code>lib/notify.ts</code>) VE ayrıca bir FCM cihaz kaydı ucu (<code>/api/devices/fcm</code>) → §52'ye aykırı çift provider
E-posta	Platform bildirim e-posta API'si (Abacus notification)
Ödeme	Kredi/jeton paketleri + manuel/entegre ödeme akışı (<code>Payment</code> , <code>PaymentMethod</code> , <code>PaymentNotification</code> , <code>CfcPaymentRequest</code>)
PDF / medya işleme	Abacus HTML2PDF ve FFmpeg API'leri (üretim ortamında yerel ffmpeg yok)
LLM	Abacus RouteLLM (<code>/api/fortunes/*</code> altında 15 adet streaming fal ucu)
Deployment	Abacus üzerinde tek hostname <code>canlifal.com</code> , standalone build
API versiyonlama	<code>middleware.ts</code> : <code>/api/v1/*</code> → <code>/api/*</code> rewrite, yanıtta <code>x-api-version: v1</code> . Geriye dönük uyumlu (eski Flutter build'leri <code>/api/...</code> ile çalışmaya devam ediyor)
Rate limit	<code>lib/rate-limiter.ts</code> (bellek içi) — 737 handler'ın sadece 9'unda uygulanmış
Observability	

Konu	Mevcut durum
	<code>lib/perf.ts</code> : <code>withPerfHeaders</code> , <code>checkETag</code> , <code>recordTiming</code> , <code>withTiming</code> , <code>getMonitoring-Snapshot</code> + <code>/api/monitoring</code>
CI/CD	Platform yönetimli build + checkpoint + deploy. Ayrı pipeline yok

Kritik mimari riskler

#	Risk	Açıklama	Şiddet
R1	Bellek içi event bus	5 realtime bus ve rate limiter process belleğinde. Uygulama birden fazla instance'a ölçeklendiğinde event'ler kullanıcıların bir kısmına ulaşmaz. Bugün tek instance olduğu için çalışıyor	Yüksek
R2	Bellek içi cache	Aynı sebep: instance başına ayrı cache, invalidation instance'lar arası yayılmaz	Yüksek
R3	WebSocket yok	Tüm realtime SSE + polling. Client→server anlık kanal yok; her aksiyon ayrı HTTP isteği	Orta
R4	Çift push provider	OneSignal + FCM ucu birlikte duruyor; çift bildirim / tutarsız token yönetimi riski	Orta
R5	Standart hata modeli yok	44 route dosyası {success:false,error:{code,message}} zarfını kullanıyor, 376'sı düz {error:'...'} döndürüyor. request_id hiçbirinde yok	Yüksek
R6	Idempotency neredeyse yok	Sadece 4 uçta idempotency izi var (gifts/goals, gifts/battles, trtc/usersig, trtc/token). Hediye/ödeme çift	Yüksek

#	Risk	Açıklama	Şiddet
		gönderiminde koruma yok	
R7	Değiştirilemez ledger yok	Finansal hareketler güncellenebilir tablolarda; denetim izi yok	Yüksek
R8	Audit log yok	Admin işlemleri (jeton ekleme, ban, para çekme onayı) izlenmiyor	Yüksek
R9	Rate limit kapsamı %1	737 handler'ın 9'u korunuyor	Orta
R10	Bootstrap ucu yok	Oda/canlı yayın açılışında client 5-8 ayrı istek atıyor	Orta
R11	Cursor pagination standardı yok	Liste uçları çoğunlukla offset/limit veya tamamını dönüyor	Orta
R12	Feature flag / remote config altyapısı yok	platform_settings üzerinde 8 anahtarlık sabit allowlist	Orta

D. REALTIME ENVANTERİ

SSE uçları (20 adet, text/event-stream)

Gerçek olay kanalları (5):

Endpoint	Kaynak bus	Yayınlanan olaylar
GET /api/chat/rooms/[roomId]/stream	chat-events.ts + voice-room-events.ts + chat-dj-events.ts	message , typing , presence , gift , user_joined , user_left , mic_changed , seat_changed , room_closed , voice_request_created , voice_request_approved , voice_request_rejected , voice_request_cancelled , speak_blocked , pk_invite , owner_changed , dj_update , online_count
GET /api/video-streams/[streamId]/stream	stream-events.ts	comment , like , gift , viewer_joined , viewer_left , stream_ended , co_broadcaster_* , moderator_* , fortune_request
GET /api/room/[sessionId]/stream	room-events.ts	Falçı seans odası sinyalleri / mesajları
GET /api/fortune-tellers/sessions/stream	room-events.ts (teller kanalı)	Falçıya gelen seans talepleri
GET /api/notifications/stream	DB polling	notification
GET /api/pk/[matchId]/stream	DB polling + PkEvent	PK skor / durum güncellemeleri

LLM streaming uçları (15): /api/fortunes/{kahve-fali, kahve-fali-image, tarot-fali, el-fali, ruya-yorumu, burc-yorumu, dogum-haritasi, numeroloji, katina, melek-kartlari, istihare, evet-hayir, aura-analizi, ask-uyumu, ...} — bunlar olay kanalı değil, token streaming.

Olay standardı — mevcut durum

Spec gereği (§23)	Mevcut
event_id	✗ yok
event_type	✓ var (bus'a göre type alanı)
version	✗ yok
timestamp	✓ çoğu event'te var
entity_id	⚠ kısmen (roomId/streamId ayrı alanlarda)
actor_id	⚠ kısmen
payload	✓ ama şema event'ten event'e değişiyor
Sequence number	✓ since imleci var (bus içi artan id) — dedupe için kullanılabilir ama client sözleşmesinde tanımlı değil
Dedupe garantisi	✗ client tarafına bırakılmış
Reconnect + resync	⚠ since parametresi ile kısmi replay var (bellek içi, sınırlı pencere)

Sonuç: olay katmanı çalışıyor ama **birleşik bir event zarfı (envelope) yok**. Faz 4'ün ana işi bu zarfı geriye dönük uyumlu şekilde eklemek olmalı (mevcut alanlar korunarak event_id / version / entity_id / actor_id **eklenecek**, hiçbiri kaldırılmayacak).